

## 1. Overview

This document describes the SAP User Access Management process implemented within IT company. The objective of this process is to provide users with proper access to SAP system based on their job responsibilities while maintaining security and audit compliance.

This project is a simulation of real-world SAP Security activities such as user creation, role creation, access requests, and periodic reviews.

The access management process is based on the Role-Based Access Control (RBAC) model and the Principle of Least Privilege.

## 2. Objectives

The key objectives of SAP User Access Management are:

- Ensure that users are granted proper access privileges to perform their job functions
- Restrict unauthorized access to critical business information
- Enforce Segregation of Duties (SoD)
- Maintain security policies within the organization
- Facilitate audits and governance

## 3. SAP User Types

The following user types are used:

| <u><b>User Type</b></u> | <u><b>Description</b></u>                              |
|-------------------------|--------------------------------------------------------|
| Dialog User             | Used by employees for day-to-day business activities   |
| System User             | Used for system integration                            |
| Communication User      | Used for external system communication                 |
| Service User            | Used for shared or anonymous access (restricted usage) |

In this project, I focused on Dialog User.

## 4. User Creation Process (Simulated SU01)

In a real SAP environment, users are created using TCode SU01.

Steps involved:

- Received access request from business user
- Verifying the request with the manager
- Creating the user account in the SAP system
- Assigning the initial password
- Assigning appropriate roles
- Activating the account

User information maintained in SAP system:

- User ID
- Full Name
- Department
- Job Title
- User Type
- Account Status

## 5. Role Creation Process (Simulated PFCG)

Roles are created using TCode PFCG in SAP. Roles define what actions a user can perform in the SAP system.

Each role contains:

- Role Name
- Description
- SAP Module (FI, MM, HCM, BASIS)
- TCodes
- Risk Level

Example roles include:

- Z\_FI\_ACCOUNTANT
- Z\_FI\_MANAGER
- Z\_MM\_PURCHASER
- Z\_HR\_MANAGER
- Z\_SAP\_SECURITY\_ADMIN

## 6. Role Assignment Process

Role assignment is performed by the SAP Security Admin.

Steps:

- Receive approved access request
- Verify business justification
- Assign appropriate roles to user
- Document assignment details
- Notify users of access availability

Role assignment information includes:

- User ID
- User Name
- Role Assigned
- Assigned By
- Assignment Date

## 7. Access Request and Approval Process

All access requests must follow an approval workflow.

Workflow steps:

- User submits access request
- Manager reviews and approves request
- SAP Security team reviews request
- Access is granted if approved
- Assignment is documented

Access request information includes:

- Request ID
- Requestor Name
- Requested Role
- Business Justification
- Manager's Approval
- Security Approval
- Status

## 8. Access Review and Audit Process

Periodic access reviews are conducted to ensure compliance and security.

Objectives:

- Identify excessive access
- Review high-risk roles
- Remove unnecessary access
- Ensure compliance with security policies and procedures

High-risk roles include:

- SAP Security Admin
- Finance Manager
- Basis Administrator

## 9. Risk Classification

Roles are classified based on risk level

| <u>Risk Level</u> | <u>Description</u>                  |
|-------------------|-------------------------------------|
| Low               | Minimal impact roles                |
| Medium            | Moderate business impact            |
| High              | Critical system or financial access |

High-risk roles require additional approval and periodic reviews.

## 10. Security Principles applied

The following security principles are implemented:

- I. Least Privilege:  
Users are granted only the minimum access required to perform their job functions.
- II. Role-Based Access Control (RBAC)  
Access is assigned using predefined roles rather than individual permissions.
- III. Segregation of Duties (SoD)  
Conflicting roles are not assigned to the same user to prevent fraud and errors.  
Example conflict:
  - Finance posting role
  - Finance approval role
- IV. Periodic Access Review  
User access is reviewed quarterly to ensure continued business need.

## 11. Benefits of Access Management Process

This process ensures:

- Improved system security
- Reduced risk of unauthorized access
- Better audit compliance
- Proper access governance
- Controlled and documented access lifecycle

## 12. Conclusion

This project presents a simulated SAP User Access Management lifecycle used in companies.

The project covers:

- User creation
- Role creation

- Role assignment
- Access request workflow
- Access review and audit

### 13. Diagram

